



ZAP by Checkmarx Scanning

Report

Site: <http://petclinic-app:8080>

Generated on Tue, 7 Jul 2026 04:18:38

ZAP Version: 2.17.0

ZAP by [Checkmarx](#)

Summary of Alerts

Risk Level	Number of Alerts
High	0
Medium	4
Low	3
Informational	2
False Positives:	0

Insights

Level	Reason	Site	Description	Statistic
Low	Warning		ZAP errors logged - see the zap.log file for details	1
Low	Warning		ZAP warnings logged - see the zap.log file for details	30
Info	Informational	http://petclinic-app:8080	Percentage of responses with status code 2xx	8 %
Info	Informational	http://petclinic-app:8080	Percentage of responses with status code 4xx	85 %
Info	Informational	http://petclinic-app:8080	Percentage of responses with status code 5xx	6 %
Info	Informational	http://petclinic-app:8080	Percentage of endpoints with content type application/json	17 %
Info	Informational	http://petclinic-app:8080	Percentage of endpoints with content type application/vnd.spring-boot.actuator.v3+json	5 %
Info	Informational	http://petclinic-app:8080	Percentage of endpoints with content type image/png	11 %
Info	Informational	http://petclinic-app:8080	Percentage of endpoints with content type image/svg+xml	5 %
Info	Informational	http://petclinic-app:8080	Percentage of endpoints with content type text/css	11 %

Info	Informational	http://petclinic-app:8080	Percentage of endpoints with content type text/html	41 %
Info	Informational	http://petclinic-app:8080	Percentage of endpoints with content type text/javascript	5 %
Info	Informational	http://petclinic-app:8080	Percentage of endpoints with method GET	94 %
Info	Informational	http://petclinic-app:8080	Percentage of endpoints with method POST	5 %
Info	Informational	http://petclinic-app:8080	Count of total endpoints	17
Info	Informational	http://petclinic-app:8080	Percentage of slow responses	1 %

Summary of Sequences

For each step: result (Pass/Fail) - risk (of highest alert(s) for the step, if any).

Alerts

Name	Risk Level	Number of Instances
Absence of Anti-CSRF Tokens	Medium	2
Content Security Policy (CSP) Header Not Set	Medium	Systemic
Missing Anti-clickjacking Header	Medium	Systemic
Spring Actuator Information Leak	Medium	1
Application Error Disclosure	Low	1
Information Disclosure - Debug Error Messages	Low	1
X-Content-Type-Options Header Missing	Low	Systemic
User Agent Fuzzer	Informational	Systemic
User Controllable HTML Element Attribute (Potential XSS)	Informational	7

Alert Detail

Medium

Absence of Anti-CSRF Tokens

Description

No Anti-CSRF tokens were found in a HTML submission form.

A cross-site request forgery is an attack that involves forcing a victim to send an HTTP request to a target destination without their knowledge or intent in order to perform an action as the victim. The underlying cause is application functionality using predictable URL/form actions in a repeatable way. The nature of the attack is that CSRF exploits the trust that a web site has for a user. By contrast, cross-site scripting (XSS) exploits the trust that a user has for a web site. Like XSS, CSRF attacks are not necessarily cross-site, but they can be. Cross-site request forgery is also known as CSRF, XSRF, one-click attack, session riding, confused deputy, and sea surf.

CSRF attacks are effective in a number of situations, including:

- * The victim has an active session on the target site.

* The victim is authenticated via HTTP auth on the target site.

* The victim is on the same local network as the target site.

CSRF has primarily been used to perform an action against a target site using the victim's privileges, but recent techniques have been discovered to disclose information by gaining access to the response. The risk of information disclosure is dramatically increased when the target site is vulnerable to XSS, because XSS can be used as a platform for CSRF, allowing the attack to operate within the bounds of the same-origin policy.

URL	http://petclinic-app:8080/owners/new
Node Name	http://petclinic-app:8080/owners/new
Method	GET
Parameter	
Attack	
Evidence	<form class="form-horizontal" id="add-owner-form" method="post"> No known Anti-CSRF token [anticsrf, CSRFToken, __RequestVerificationToken, csrfmiddlewaretoken, authenticity_token, OWASP_CSRFTOKEN, anoncsrf, csrf_token, _csrf, _csrfSecret, __csrf_magic, CSRF, _token, _csrf_token, _csrfToken] was found in the following HTML form: [Form 1: "address" "city" "firstName" "lastName" "telephone"].
Other Info	
URL	http://petclinic-app:8080/owners/new
Node Name	http://petclinic-app:8080/owners/new ()(address,city,firstName,lastName,telephone)
Method	POST
Parameter	
Attack	
Evidence	<form class="form-horizontal" id="add-owner-form" method="post"> No known Anti-CSRF token [anticsrf, CSRFToken, __RequestVerificationToken, csrfmiddlewaretoken, authenticity_token, OWASP_CSRFTOKEN, anoncsrf, csrf_token, _csrf, _csrfSecret, __csrf_magic, CSRF, _token, _csrf_token, _csrfToken] was found in the following HTML form: [Form 1: "address" "city" "firstName" "lastName" "telephone"].
Other Info	
Instances	2
Solution	Phase: Architecture and Design

Use a vetted library or framework that does not allow this weakness to occur or provides constructs that make this weakness easier to avoid.

For example, use anti-CSRF packages such as the OWASP CSRFGuard.

Phase: Implementation

Ensure that your application is free of cross-site scripting issues, because most CSRF defenses can be bypassed using attacker-controlled script.

Phase: Architecture and Design

Generate a unique nonce for each form, place the nonce into the form, and verify the nonce upon receipt of the form. Be sure that the nonce is not predictable (CWE-330).

Note that this can be bypassed using XSS.

Identify especially dangerous operations. When the user performs a dangerous operation, send a separate confirmation request to ensure that the user intended to perform that operation.

Note that this can be bypassed using XSS.

Use the ESAPI Session Management control.

This control includes a component for CSRF.

Do not use the GET method for any request that triggers a state change.

Phase: Implementation

Check the HTTP Referer header to see if the request originated from an expected page. This could break legitimate functionality, because users or proxies may have disabled sending the Referer for privacy reasons.

https://cheatsheetseries.owasp.org/cheatsheets/Cross-Site_Request_Forgery_Prevention_Cheat_Sheet.html
<https://cwe.mitre.org/data/definitions/352.html>

Reference

CWE Id [352](#)

WASC Id 9

Plugin Id [10202](#)

Medium

Content Security Policy (CSP) Header Not Set

Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.

Description

URL <http://petclinic-app:8080/>

Node Name http://petclinic-app:8080/

Method GET

Parameter

Attack

Evidence

Other Info

URL <http://petclinic-app:8080/owners?lastName=ZAP>

Node Name http://petclinic-app:8080/owners (lastName)

Method GET

Parameter

Attack

Evidence

Other Info

URL <http://petclinic-app:8080/owners/find>

Node Name http://petclinic-app:8080/owners/find

Method	GET
Parameter	
Attack	
Evidence	
Other Info	
URL	http://petclinic-app:8080/vets.html
Node Name	http://petclinic-app:8080/vets.html
Method	GET
Parameter	
Attack	
Evidence	
Other Info	
URL	http://petclinic-app:8080/owners/new
Node Name	http://petclinic-app:8080/owners/new ()(address,city,firstName,lastName,telephone)
Method	POST
Parameter	
Attack	
Evidence	
Other Info	
Instances	Systemic
Solution	Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header. https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html https://www.w3.org/TR/CSP/
Reference	https://w3c.github.io/webappsec-csp/ https://web.dev/articles/csp https://caniuse.com/#feat=contentsecuritypolicy https://content-security-policy.com/
CWE Id	693
WASC Id	15
Plugin Id	10038

Medium

Missing Anti-clickjacking Header

Description	The response does not protect against 'ClickJacking' attacks. It should include either Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.
URL	http://petclinic-app:8080/
Node Name	http://petclinic-app:8080/
Method	GET
Parameter	x-frame-options
Attack	
Evidence	
Other Info	
URL	http://petclinic-app:8080/owners?lastName=ZAP
Node Name	http://petclinic-app:8080/owners (lastName)
Method	GET

Parameter	x-frame-options
Attack	
Evidence	
Other Info	
URL	http://petclinic-app:8080/vets.html
Node Name	http://petclinic-app:8080/vets.html
Method	GET
Parameter	x-frame-options
Attack	
Evidence	
Other Info	
Instances	Systemic
	Modern Web browsers support the Content-Security-Policy and X-Frame-Options HTTP headers. Ensure one of them is set on all web pages returned by your site/app.
Solution	If you expect the page to be framed only by pages on your server (e.g. it's part of a FRAMESET) then you'll want to use SAMEORIGIN, otherwise if you never expect the page to be framed, you should use DENY. Alternatively consider implementing Content Security Policy's "frame-ancestors" directive.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options
CWE Id	1021
WASC Id	15
Plugin Id	10020

Medium

Spring Actuator Information Leak

Description	Spring Actuator for Health is enabled and may reveal sensitive information about this application. Spring Actuators can be used for real monitoring purposes, but should be used with caution as to not expose too much information about the application or the infrastructure running it.
URL	http://petclinic-app:8080/actuator/health
Node Name	http://petclinic-app:8080/actuator/health
Method	GET
Parameter	
Attack	
Evidence	{"groups":["liveness","readiness"],"status":"UP"}
Other Info	
Instances	1
Solution	Disable the Health Actuators and other actuators, or restrict them to administrative users.
Reference	https://docs.spring.io/spring-boot/api/rest/actuator/index.html#overview
CWE Id	215
WASC Id	13
Plugin Id	40042

Low

Application Error Disclosure

Description	This page contains an error/warning message that may disclose sensitive information like the location of the file that produced the unhandled exception. This information can be
-------------	--

used to launch further attacks against the web application. The alert could be a false positive if the error message is found inside a documentation page.

URL	http://petclinic-app:8080/oups
Node Name	http://petclinic-app:8080/oups
Method	GET
Parameter	
Attack	
Evidence	HTTP/1.1 500
Other Info	
Instances	1
Solution	Review the source code of this page. Implement custom error pages. Consider implementing a mechanism to provide a unique error reference/identifier to the client (browser) while logging the details on the server side and not exposing them to the user.
Reference	
CWE Id	550
WASC Id	13
Plugin Id	90022

Low

Information Disclosure - Debug Error Messages

Description	The response appeared to contain common error messages returned by platforms such as ASP.NET, and Web-servers such as IIS and Apache. You can configure the list of common debug messages.
URL	http://petclinic-app:8080/oups
Node Name	http://petclinic-app:8080/oups
Method	GET
Parameter	
Attack	
Evidence	Internal Server Error
Other Info	
Instances	1
Solution	Disable debugging messages before pushing to production.
Reference	
CWE Id	1295
WASC Id	13
Plugin Id	10023

Low

X-Content-Type-Options Header Missing

Description	The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.
URL	http://petclinic-app:8080/
Node Name	http://petclinic-app:8080/
Method	GET
Parameter	x-content-type-options

Attack
Evidence

This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type.

Other Info

At "High" threshold this scan rule will not alert on client or server error responses.

URL <http://petclinic-app:8080/resources/images/favicon.png>

Node Name http://petclinic-app:8080/resources/images/favicon.png

Method GET

Parameter x-content-type-options

Attack

Evidence

This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type.

Other Info

At "High" threshold this scan rule will not alert on client or server error responses.

URL <http://petclinic-app:8080/resources/images/pets.png>

Node Name http://petclinic-app:8080/resources/images/pets.png

Method GET

Parameter x-content-type-options

Attack

Evidence

This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type.

Other Info

At "High" threshold this scan rule will not alert on client or server error responses.

URL <http://petclinic-app:8080/resources/images/spring-logo.svg>

Node Name http://petclinic-app:8080/resources/images/spring-logo.svg

Method GET

Parameter x-content-type-options

Attack

Evidence

This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type.

Other Info

At "High" threshold this scan rule will not alert on client or server error responses.

URL <http://petclinic-app:8080/webjars/font-awesome/4.7.0/css/font-awesome.min.css>

Node Name http://petclinic-app:8080/webjars/font-awesome/4.7.0/css/font-awesome.min.css

Method GET

Parameter x-content-type-options

Attack

Evidence

Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type.
Instances	At "High" threshold this scan rule will not alert on client or server error responses. Systemic Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages.
Solution	If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by the web application/web server to not perform MIME-sniffing.
Reference	https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85) https://owasp.org/www-community/Security-Headers
CWE Id	693
WASC Id	15
Plugin Id	10021

Informational

User Agent Fuzzer

Description	Check for differences in response based on fuzzed User Agent (eg. mobile sites, access as a Search Engine Crawler). Compares the response statuscode and the hashcode of the response body with the original response.
URL	http://petclinic-app:8080/oups
Node Name	http://petclinic-app:8080/oups
Method	GET
Parameter	Header User-Agent
Attack	Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1)
Evidence	
Other Info	
URL	http://petclinic-app:8080/oups
Node Name	http://petclinic-app:8080/oups
Method	GET
Parameter	Header User-Agent
Attack	Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.0)
Evidence	
Other Info	
URL	http://petclinic-app:8080/oups
Node Name	http://petclinic-app:8080/oups
Method	GET
Parameter	Header User-Agent
Attack	Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 6.1)
Evidence	
Other Info	
Instances	Systemic
Solution	
Reference	https://owasp.org/wstg

CWE Id
WASC Id
Plugin Id

[10104](#)

Informational

User Controllable HTML Element Attribute (Potential XSS)

Description	This check looks at user-supplied input in query string parameters and POST data to identify where certain HTML attribute values might be controlled. This provides hot-spot detection for XSS (cross-site scripting) that will require further review by a security analyst to determine exploitability.
URL	http://petclinic-app:8080/owners?lastName=ZAP
Node Name	http://petclinic-app:8080/owners (lastName)
Method	GET
Parameter	lastName
Attack	
Evidence	User-controlled HTML attribute values were found. Try injecting special characters to see if XSS might be possible. The page at the following URL: http://petclinic-app:8080/owners?lastName=ZAP appears to include user input in:
Other Info	a(n) [input] tag [value] attribute The user input found was: lastName=ZAP The user-controlled value was: zap
URL	http://petclinic-app:8080/vets.html?page=1
Node Name	http://petclinic-app:8080/vets.html (page)
Method	GET
Parameter	page
Attack	
Evidence	
Other Info	User-controlled HTML attribute values were found. Try injecting special characters to see if XSS might be possible. The page at the following URL: http://petclinic-app:8080/vets.html?page=1 appears to include user input in: a(n) [meta] tag [content] attribute The user input found was: page=1

	The user-controlled value was:
	width=device-width, initial-scale=1
URL	http://petclinic-app:8080/owners/new
Node Name	http://petclinic-app:8080/owners/new ()(address,city,firstName,lastName,telephone)
Method	POST
Parameter	address
Attack	
Evidence	User-controlled HTML attribute values were found. Try injecting special characters to see if XSS might be possible. The page at the following URL:
	http://petclinic-app:8080/owners/new
	appears to include user input in:
Other Info	a(n) [input] tag [value] attribute
	The user input found was:
	address=688 Zaproxy Ridge
	The user-controlled value was:
	688 zaproxy ridge
URL	http://petclinic-app:8080/owners/new
Node Name	http://petclinic-app:8080/owners/new ()(address,city,firstName,lastName,telephone)
Method	POST
Parameter	city
Attack	
Evidence	User-controlled HTML attribute values were found. Try injecting special characters to see if XSS might be possible. The page at the following URL:
	http://petclinic-app:8080/owners/new
	appears to include user input in:
Other Info	a(n) [input] tag [value] attribute
	The user input found was:
	city=East Romaineburgh
	The user-controlled value was:
	east romaineburgh
URL	http://petclinic-app:8080/owners/new
Node Name	http://petclinic-app:8080/owners/new ()(address,city,firstName,lastName,telephone)
Method	POST

Parameter	firstName
Attack	
Evidence	User-controlled HTML attribute values were found. Try injecting special characters to see if XSS might be possible. The page at the following URL: http://petclinic-app:8080/owners/new appears to include user input in:
Other Info	a(n) [input] tag [value] attribute The user input found was: firstName=ZAP The user-controlled value was: zap
URL	http://petclinic-app:8080/owners/new
Node Name	http://petclinic-app:8080/owners/new ()(address,city,firstName,lastName,telephone)
Method	POST
Parameter	lastName
Attack	
Evidence	User-controlled HTML attribute values were found. Try injecting special characters to see if XSS might be possible. The page at the following URL: http://petclinic-app:8080/owners/new appears to include user input in:
Other Info	a(n) [input] tag [value] attribute The user input found was: lastName=ZAP The user-controlled value was: zap
URL	http://petclinic-app:8080/owners/new
Node Name	http://petclinic-app:8080/owners/new ()(address,city,firstName,lastName,telephone)
Method	POST
Parameter	telephone
Attack	
Evidence	
Other Info	User-controlled HTML attribute values were found. Try injecting special characters to see if XSS might be possible. The page at the following URL:

http://petclinic-app:8080/owners/new

appears to include user input in:

a(n) [input] tag [value] attribute

The user input found was:

telephone=ZAP

The user-controlled value was:

zap

Instances

7

Solution

Validate all input and sanitize output it before writing to any HTML attributes.

Reference

https://cheatsheetseries.owasp.org/cheatsheets/Input_Validation_Cheat_Sheet.html

CWE Id

[20](#)

WASC Id

20

Plugin Id

[10031](#)

Sequence Details

With the associated active scan results.